Coordinated Security & Privacy Disclosure, Final Report

Baby Panda’s Food Story for Android (com.sinyee.babybus.foodstory, v8.73.00.00)

Thirteen written notices, ninety days, total silence – not one reply of any kind, a children’s app carrying nineteen advertising SDKs

PUBLIC DISCLOSURE, 19 SEPTEMBER 2026 – ALL THREE FINDINGS UNADDRESSED AFTER THIRTEEN NOTICES, ZERO REPLIES

Target	BabyBus (Fujian) Network Technology Co., Ltd.
Product audited	Baby Panda’s Food Story for Android, com.sinyee.babybus.foodstory, v8.73.00.00 (APK SHA-256: c8cada40101968201156b225edf26df0d0e6b4aa8df9a9e536de38dd6fa284de)
Disclosure reference	REF BABYBUS-R1
R1 sent	2026-06-25
Disclosure / embargo date	2026-09-19
Report published	2026-09-19
Severity	CRITICAL (C1 approximately nineteen advertising and tracking SDKs bundled in a children’s app, with Firebase auto-initializing before any consent screen, CVSS v4.0 8.7, unaddressed)

rfi.irfos@gmail.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Graz, Austria

Contents

1 Executive Summary 3

2 Subject & Operator Analysis 4

3 Findings 4

3.1 C1: Approximately nineteen advertising and tracking SDKs bundled in a children's app . . . 4

3.2 H1: Advertising-identifier permissions collect interest-based signals from children . . . 4

3.3 H2: Audio/media data endpoints plus development, beta, and simulation hostnames in the production binary . . . 5

4 Thirteen Notices, One Thread, Zero Replies 5

5 Data Protection, Article by Article 5

6 Disclosure Timeline & Outcome 6

7 Residual Risk & Recommendations 6

Executive Summary

On 25 June 2026, RFI-IRFOS performed static analysis of the production Baby Panda's Food Story Android application, a children's app, and identified one CRITICAL and two HIGH findings: approximately nineteen advertising and tracking SDKs bundled into the app, ByteDance/Pangle, Mintegral, Tencent, Umeng, Facebook, AppLovin, ironSource/Supersonic, Vungle, InMobi, Chartboost, Fyber, Tapjoy, Unity Ads, Google Ads, Amplitude, and Firebase among them, with Firebase's auto-initialization provider running before any consent screen is shown, advertising-identifier permissions (ACCESS_ADSERVICES_AD_ID, ACCESS_ADSERVICES_ATTRIBUTION, ACCESS_ADSERVICES_TOPICS) enabling interest-based advertising signal collection from a child-directed app, and audio/media data endpoints alongside development, beta, and simulation-environment hostnames all referenced in the shipped production binary.

Across thirteen written notices over ninety days on a single continuous thread, cc'd throughout to the Austrian Datenschutzbehoerde, the European Data Protection Supervisor, and, from 12 August, CERT.at, not one reply of any kind, automated or human, was ever received from BabyBus. None of RFI-IRFOS's three standing questions, posed as yes/no/before-after remediation questions in R1, ever received an answer.

Scope: Static analysis of the publicly downloaded production Baby Panda's Food Story Android APK (v8.73.00.00), on an authorized test device, only. No BabyBus account, backend, or infrastructure was accessed or tested.

Disposition

R1 sent 25 June 2026 to privacy@babybus.com and babypandaworld@babybus.com, cc the Austrian Datenschutzbehoerde and the European Data Protection Supervisor, with CERT.at added from 12 August. Across thirteen written notices over ninety days on a single continuous thread, not one reply of any kind, automated or human, was ever received from BabyBus.

ID	Severity	Title
C1	CRITICAL	Approximately nineteen advertising and tracking SDKs bundled in a children's app
H1	HIGH	Advertising-identifier permissions collect interest-based signals from children
H2	HIGH	Audio/media data endpoints plus development, beta, and simulation hostnames in the production binary

Subject & Operator Analysis

BabyBus (Fujian) Network Technology Co., Ltd. is implied as the operator by the app's package name and the babybus.com domain used in correspondence; this was not independently confirmed through any reply, since none was ever received.

Findings

C1: Approximately nineteen advertising and tracking SDKs bundled in a children's app

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.7

The app ships approximately nineteen advertising/tracking SDKs: ByteDance/Pangle, Mintegral (mbridge), Tencent, Umeng, Facebook (Meta), AppLovin, ironSource/Supersonic, Vungle, InMobi, Chartboost, Fyber, Tapjoy, Unity Ads, Google Ads, Amplitude, and Firebase. Firebase's auto-initialization ContentProvider runs before any consent screen is presented to the user.

No reply of any kind, across thirteen notices, addressed this finding.

Impact: A children's app initializes a broad advertising and tracking infrastructure, including multiple Chinese and US networks, before any consent decision can be made.

Fix: Gate all advertising and tracking SDK initialization behind an affirmative, age-appropriate consent decision, and substantially reduce the number of third-party trackers bundled.

H1: Advertising-identifier permissions collect interest-based signals from children

HIGH, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:N/VA:N/SC:N/SI:N/SA:N, 8.7

ACCESS_ADSERVICES_AD_ID, ACCESS_ADSERVICES_ATTRIBUTION, and ACCESS_ADSERVICES_TOPICS permissions are all present, enabling interest-based advertising signal collection from a child-directed app.

No reply of any kind addressed this finding.

Impact: Interest-based advertising profiles may be constructed from children's app usage with no confirmed age-appropriate consent gate.

Fix: Remove advertising-identifier permissions from a child-directed app, consistent with platform child-safety policies.

H2: Audio/media data endpoints plus development, beta, and simulation hostnames in the production binary

MEDIUM, CVSS v4.0 AV:N/AC:L/AT:N/PR:N/UI:N/VC:L/VI:N/VA:N/SC:N/SI:N/SA:N, 6.9

Endpoints api-audiodata.babybus.com, api-mediadata.babybus.com, and act-api.babybus.com, alongside non-production hostnames act-api.beta.babybus.com, act-api.dev.babybus.com, and act-api.sim.babybus.com, are all referenced in the shipped production APK.

No reply of any kind addressed this finding.

Impact: Non-production infrastructure hostnames are exposed in a production release intended for children, indicating a release-hygiene gap.

Fix: Remove development, beta, and simulation-environment hostname references from production release builds.

Thirteen Notices, One Thread, Zero Replies

This case ran as a single continuous Gmail thread across thirteen written notices and ninety days. Not one reply of any kind, automated or human, was ever received from BabyBus at either privacy@babybus.com or babypandaworld@babybus.com.

Data Protection, Article by Article

Finding	Provision	Concern
C1	GDPR Art. 8, Art. 6(1)	Pre-consent initialization of a broad advertising/tracking SDK stack on a children's app
H1	GDPR Art. 8, Art. 5(1)(c)	Advertising-identifier collection from children
H2	GDPR Art. 32	Non-production infrastructure exposed in a production release

Disclosure Timeline & Outcome

Date	Event
2026-06-25	R1 sent to privacy@babybus.com and babypandaworld@babybus.com, cc Austrian DSB and EDPS; 1 CRITICAL + 2 HIGH findings
2026-07-03	Follow-up confirms Austrian DSB and EDPS in cc
2026-08-12	Follow-up, day 48, five messages, CERT.at added to cc
2026-08-28	Follow-up, day 64, ten messages, re-states the nineteen-advertising-network finding
2026-09-12	Follow-up, seventy-nine days, twelve messages, zero replies, most recent message on file
2026-09-19	Embargo, as stated identically throughout the correspondence, closes and this report publishes

Residual Risk & Recommendations

- Establish a functioning privacy contact capable of responding to GDPR disclosures.
- Gate all advertising and tracking SDK initialization behind an affirmative, age-appropriate consent decision.
- Remove advertising-identifier permissions from this child-directed app.
- Remove development, beta, and simulation-environment hostname references from production release builds.

RFI-IRFOS rfi.irfos@gmail.com • rfi-irfos.com

ZVR 1015608684 • GISA 39261441 • UID ATU83405245 • Steuernummer 68 696/8736 • Elisabethinergasse 25/10, 8020 Graz, Austria Coordinated disclosure per ISO/IEC 29147. GDPR Art. 5, 6, 8, 32. REF BABYBUS-R1.